

(주)플라이메이트 수탁사 개선 방안 보고서

수탁사 (피감사)	(주)플라이메이트
위탁사 (감사 주체)	(주)하랑항공
위탁 업무 범위	공항 지상 조업 서비스 일체 대행
점검 기간	2026년 01월 26일 ~ 2026년 02월 13일
작성일	2026년 02월 23일

본 보고서는 (주)플라이메이트의 개인정보 보호 관리 수준을 점검한 결과를 바탕으로,
각 취약 사항에 대한 구체적인 개선방안과 이행 계획을 기술한 문서입니다.

목차

1. 개선방안 요약	3
1.1 보안 준수율 분류 기준	3
1.2 조치 기한 분류 기준	3
2. 범주별 개선방안 상세	4
2.1 내부 관리 계획 및 조직	4
2.2 접근 통제 및 권한 관리	5
2.3 접속기록 보관 및 점검	6
2.4 비밀번호 관리	7
2.5 접속 보안 및 네트워크	7
2.6 단말기 보안	8
2.7 개인정보 암호화 및 출력 통제	9
2.8 개인정보 생명주기	10
3. 이행 점검 로드맵	13
4. 결론 및 향후 조치 계획	14
4.1 향후 조치 일정	14

1. 개선방안 요약

1.1 보안 준수율 분류 기준

분류	양호(Y)	부분양호(P)	취약(N)
점수	1	0.7	0

총점	100 ~ 90	89 ~ 70	69 ~ 50	49 ~ 0
등급	A	B	C	D

- 각 점검항목을 양호, 부분양호, 취약으로 평가하여 분류한다.
- 총점은 53개의 점검항목 점수의 합산을 100점 만점으로 환산한 값이다.
- 환산 점수에 따라 90점 이상 A등급, 70~89점 B등급, 50~69점 C등급, 49점이하 D등급으로 산정한다.

1.2 조치 기한 분류 기준

구분	긴급	단기	중기
조치 기한	4주	2개월	6개월

- 지적 사항의 심각도에 따라 조치기한을 3단계로 구분한다.
- 개선방안 이행은 긴급, 단기, 중기 순으로 추진한다.

2. 범주별 개선방안 상세

2.1 내부 관리 계획 및 조직

점검 결과 등급: B

■ 긴급 조치 항목 (4주 이내)

구분	현황·문제점	개선 방안	담당자
출력물 보관	D열 5번 카운터에서 탑승 거절 승객 여권 사본 2매 방치, 다음 승객 3명에게 여권번호·성명·생년월 일 노출	민감 서류 즉시 수거 절차 전 직원 재교육, 카운터 점검 체크리스트 도입, 위반 시 징계 절차 명문화	현장운영팀장 김태호
침해사고 즉시 보고	DCS 장애 발생 후 위탁사 통보까지 28시간 경과 (즉시 보고 의무 위반), 비상연락망 내 야간 담당자 정보 5개월 이상 미갱신, 주말 비상 담당자 미지정, 주말 사고 시 보고 채널 단절 위험,현장 담당자가 72시간 내 KISA 신고·위탁사 즉시 보고 의무 미인지	비상연락망 즉시 최신화 (퇴사자 2명 담당자 교체, 주말·야간 담당자 신규 지정),침해사고 인지 즉시 위탁사 유선 보고 → 2시간 내 서면 보고 절차 수립, 분기 1회 전 직원 대상 침해사고 보고 절차 교육 및 모의 훈련 실시, 교육 이수 현황 CPO 월간 보고	보안팀장 이준혁

■ 단기 조치 항목 (2개월 이내)

구분	현황·문제점	개선 방안	담당자
위기대응 매뉴얼	BCP/DRP 매뉴얼은 수립되어 있으나 2025년 연간 DR 훈련 0회, 현장 직원(약 120명) 참여 기록 전무	반기 1회 이상 현장 직원 참여 DR 훈련 실시, 훈련 결과보고서 작성 및 CPO 보고, 참여 기록 의무화	보안팀장 이준혁, IT운영팀장 박성민
개인정보보호	여권 판독기(MRZ)	현장 특화 교육 콘텐츠 신규	교육팀장 최지은,

구분	현황·문제점	개선 방안	담당자
교육, 현장 특화 부재	조작·DCS 화면 마스킹 절차 등 지상 조업 현장 특화 콘텐츠 부재	개발(MRZ·비자 확인·DCS 마스킹 절차 등), 연 1회 이상 실시, 이수 테스트 도입	보안팀장 이준혁
물리적 출입통제	카운터 수납함 번호키 전 카운터 동일 비밀번호 설정 후 1년 6개월 미변경, 퇴사자 7명 접근 차단 무력화	번호키 즉시 교체 및 복잡 비밀번호 설정, 교대 주기마다 비밀번호 변경 절차 수립, 퇴사자 접근 차단 이력 관리	보안팀장 이준혁

2.2 접근 통제 및 권한 관리

점검 결과 등급: B

■ 긴급 조치 항목 (4주 이내)

구분	현황·문제점	개선 방안	담당자
공용 계정	교대조 공용 계정 3개 운영, 조당 3~4명 동일 PW 공유, 동시 4개 세션 접속, 개인별 감사 추적 완전 불가	공용 계정 즉시 폐지, 전 직원 1인 1계정 발급 및 전환, Windows 로그인 개인계정화, OTP 추가 인증 도입 검토	IT운영팀장 박성민

■ 단기 조치 항목 (2개월 이내)

구분	현황·문제점	개선 방안	담당자
세션 타임아웃	내부 정책 10분 대비 현장 단말기 45분 설정, 조장이 보안 승인 없이 임의 변경, 비인가 인원의 화면 접근 위험	세션 타임아웃 10분 정책 즉시 원복, 정책 변경 시 CPO 승인 필수 절차화, 수속 피크 시간 재로그인 불편 해소 대안 검토	IT운영팀장 박성민
최소 권한 원칙	조장 12명 전원에게 전체 승객 마일리지	조장별 당 항공편 범위 내 마일리지 조회로 권한 축소, 엑셀 다운로드는	IT운영팀장 박성민

구분	현황·문제점	개선 방안	담당자
	DB 일괄 조회 및 엑셀 다운로드 권한 일괄 부여, 업무 필요성 검토 기록 없음	실제 사용자(3명)에게만 부여, 권한 부여 시 필요성 검토 기록 의무화	
퇴직자 계정	인사 ERP 연동 퇴직 발령 후 평균 10분 이내 전 시스템 권한 자동 차단, 장기 미접속 계정 잔존 미발견	현행 ERP 연동 자동 차단 체계 유지, 연 1회 장기 미접속 계정 전수 점검, 연동 장애 시 수동 처리 절차 정기 훈련	IT운영팀장 박성민
접근권한 기록보관	권한 부여·변경·삭제 기록을 관리자 임의 수정 불가 형태로 3년 이상 보존, 감사 로그 위변조 방지 통제 적용	현행 계정 관리 기록 보존 체계 유지, 연 1회 보존 기간 및 기록 완결성 감사 실시	IT운영팀장 박성민

2.3 접속기록 보관 및 점검

점검 결과 등급: A

■ 중기 조치 항목 (6개월 이내)

구분	현황·문제점	개선 방안	담당자
로그 무결성	로그 정기 백업(NAS 일일+USB HDD 월간) 수행하나 SHA-256 해시값 생성·검증 절차 미구축, 백업 파일 위변조 탐지 불가, 침해사고 시 로그 증거 능력 저하 위험	SHA-256 해시값 생성·검증 절차 구축, 백업 파일별 해시 원본과 분리 보관, 분기 1회 정기 무결성 검증 이력 관리	IT운영팀장 박성민
이상행위 탐지	SIEM 실시간 연동 경보 발송 체계 완전 구현, 과도 PNR	SIEM 탐지 정책(임계값) 반기 1회 재검토, 오탐·미탐 비율 모니터링 및 경보	IT운영팀장 박성민, 보안팀장 이준혁

구분	현황·문제점	개선 방안	담당자
	조화·비정상 시간대 접속 시 CPO 즉각 경고	임계값 정기 정비	

2.4 비밀번호 관리

점검 결과 등급: C

■ 긴급 조치 항목 (4주 이내)

구분	현황·문제점	개선 방안	담당자
비밀번호 평문 노출	C열·E열 카운터 PC 모니터에 DCS 관리자 계정 PW 포스트잇 평문 기재(최소 2개소), 해당 계정은 전체 시스템 제어 가능	포스트잇 즉시 제거 및 관리자 PW 즉시 변경, 전 카운터 현장 전수 점검, 비밀번호 외부 기재 절대 금지 보안 교육 실시	보안팀장 이준혁

2.5 접속 보안 및 네트워크

점검 결과 등급: B

■ 긴급 조치 항목 (4주 이내)

구분	현황·문제점	개선 방안	담당자
비인가 원격제어	카운터 PC 32대 중 14대에 비인가 TeamViewer v15.51.6 보안 승인 없이 설치, 외부 IP 5개에서 27회 원격 접속 이력(야간 8회 포함)	TeamViewer 전면 삭제 및 GPO 통한 재설치 차단, 원격 지원 시 SSL-VPN(FortiClient) 전용 사용 정책 수립, 향후 원격 지원 이력 전수 관리	IT운영팀장 박성민

■ 중기 조치 항목 (6개월 이내)

구분	현황·문제점	개선 방안	담당자
방화벽 예외 홀	방화벽 규칙 342개 중	전수 검토 후 불필요 홀 삭제,	IT운영팀장 박성민,

구분	현황·문제점	개선 방안	담당자
	비인가 예외 홀 18건(11건 승인 기록 불명), 이후 6개월 이상 정기 검토 미 실시	미승인 11건 소급 정비, 분기 1회 방화벽 정책 검토 절차화	보안팀장 이준혁

2.6 단말기 보안

점검 결과 등급: C

■ 긴급 조치 항목 (4주 이내)

구분	현황·문제점	개선 방안	담당자
USB 통제	DLP USB 차단 정책 '허용' 상태 미적용, PC 32대 중 19대에서 개인 스마트폰 USB 연결 87회/월, MTP/PTP 파일 전송 가능 상태	DLP USB 저장장치 차단 정책 즉시 활성화(마우스·키보드 허용·저장장치 차단 분리 적용), 개인 스마트폰 USB 연결 전면 금지, 보조저장매체 반출입 관리대장 재개	IT운영팀장 박성민

■ 단기 조치 항목 (2개월 이내)

구분	현황·문제점	개선 방안	담당자
취약점 미조치	고위험 취약점 4건(DCS SQL Injection, XSS, CVE-2025-38063, 기본 PW 미변경) 점검일 이후 4개월 이상 전체 미조치	고위험 4건 긴급 조치(SQL Injection 패치, XSS 필터링, OS CVE 패치, 기본 PW 변경), 보안팀 주도 월별 이행 현황 추적 및 CSIO 보고	IT운영팀장 박성민, 개발팀장 정우찬
PC 보안 패치	WSUS 배포 체계 운영 중이나 PC 67대 중 16대 미패치, 재부팅 취소 반복, 가장 오래된 PC 2개월 이상 미패치,	미패치 16대 즉시 패치 적용, 재부팅 취소 시 자동 추적 GPO 정책 적용, WSUS 배포 상태 주간 모니터링 체계 수립	IT운영팀장 박성민

구분	현황·문제점	개선 방안	담당자
	강제 패치 절차 미비		
공유 폴더 관리	조장급 PC 3대 인수인계용 공유 폴더 PW 최초 설정 후 9개월간 동일 유지, 단일 PW 공유, 공유 폴더 내 승객 명단 파일 47건 저장 확인, 사용자별 계정 미분리, 접속로그 미기록	공유 폴더 PW 즉시 변경(복잡도 강화) 및 교대 주기(분기)마다 의무 변경 절차 수립, 사용자별 개인 계정으로 접근 권한 분리, 공유 폴더 내 승객 명단 파일 47건 즉시 안전한 위치로 이관 후 파기, 파일 서버 접근 로그 활성화 및 월 1회 접근 이력 점검 의무화	IT운영팀장 박성민 보안팀장 이준혁

2.7 개인정보 암호화 및 출력 통제

점검 결과 등급: A

■ 단기 조치 항목 (2개월 이내)

구분	현황·문제점	개선 방안	담당자
DCS 마스킹 버그	DCS v7.2.1 마일리지 조회 메뉴 버그로 조장 이상 권한 12명에게 여권번호 전체 평문 노출, 조치 일정 미정	v7.3.0 긴급 패치 배포 일정 조기 확정, 패치 전 임시 조치로 마일리지 상세 조회 권한 임시 차단(12명 대상), 위탁사와 일정 협의	IT운영팀장 박성민, 개발팀장 정우찬

■ 중기 조치 항목 (6개월 이내)

구분	현황·문제점	개선 방안	담당자
암호화 키 관리	전용 KMS 미도입(엑셀 수기 관리), NAS 접근권한 과다(IT운영팀장 박성민 5명 전체), 정기 점검 기록 부재(5개월 미갱신),	단기: 관리 Excel 접근권한 보안담당자 1인만 허용·분기 1회 점검·키 노출 대응 절차 문서화, 중기: 전용 KMS 도입(예산 확보)	IT운영팀장 박성민, 보안팀장 이준혁

구분	현황·문제점	개선 방안	담당자
	키 노출 대응 절차 미문서화		

2.8 개인정보 생명주기

점검 결과 등급: D

■ 긴급 조치 항목 (4주 이내)

구분	현황·문제점	개선 방안	담당자
위탁 범위 초과 수집	직원 5명 중 3명이 개인 스마트폰으로 여권 45매 무단 촬영 보관, 1명 iCloud 자동 동기화로 외부 클라우드 업로드, 촬영 금지 규정 부재	개인 스마트폰 여권 촬영 즉각 금지·보유 사진 즉시 전량 삭제·iCloud 동기화 Off, 취업규칙 반영, 업무 중 개인 스마트폰 사용 제한 정책 수립	현장운영팀장 김태호, 보안팀장 이준혁
목적외이용/ 무단 재위탁	조장 3명이 카카오톡 단체방(참여자 15명)에 DCS 화면 캡처 31건/월 공유, 항공사 승인 없이 재수탁자 15명 무단 재위탁, 보안 계약서 필수 조항 누락	카카오톡 개인정보 공유 즉각 금지·그룹웨어 메신저 활성화, 무단 재위탁 중단·항공사 승인 취득·계약서 재체결·재수탁자 15명 교육 실시	현장운영팀장 김태호, 경영지원팀장 한소연
파기 결과 보고 미이행	2025년 연간 CPO 파기 결과 보고 0건, 위탁사 분기 보고 의무 불이행, 연간 마감 시 탑승 서류(승객 성명·여권번호·좌석번호 포함)를 보안 수거함 대신 일반 쓰레기통 투기 사실, 파기 절차 모니터링 체계 전무	파기 결과 보고서 즉시 작성 및 CPO 보고 체계 수립(파기 후 7일 이내 CPO 보고 의무화), 위탁사 분기 1회 이상 파기 결과 보고서 제출 체계 수립, 야간조 전체 대상 보안 수거함 투입 절차 재교육 및 SOP 개정, 파기이행 모니터링 체계 구축, 파기 이행 현황 월간 CPO 보고 의무화	현장운영팀장 김태호 보안 팀장 이준혁

■ 단기 조치 항목 (2개월 이내)

구분	현황·문제점	개선 방안	담당자
제3자 제공 관리	제3자 기관 승객 정보 제공 22건이 공식 관리대장 없이 이메일로만 산발 관리, 제공 항목/법적 근거 누락	반출입 관리대장 즉시 재개, 과거 22건 소급 기록 정비, 표준 양식(수신자·제공항목·법적근거 필수 포함) 배포 및 주기적 기록 의무화	보안팀장 이준혁 운영팀장 윤재원

■ 중기 조치 항목 (6개월 이내)

구분	현황·문제점	개선 방안	담당자
DB 파기 절차 개선	보상 완료 승객 데이터가 논리적 삭제만 수행, 물리적 삭제는 월 1회 배치 작업으로 실행, 최대 30일간 실제 데이터 잔존, DB 관리자 권한으로 논리 삭제 후에도 847건 조회 가능 확인	논리 삭제 즉시 물리 삭제 처리되도록 프로세스 개선(5일 이내 파기 의무 준수), DB 관리자 권한으로 논리 삭제 데이터 조회 차단 정책 적용, 파기 배치 실행 후 파기 증적 자동 기록 체계 구축, 기 완료 사실 분기 1회 CPO 보고	IT운영팀장 박성민 개발팀장 정우찬
보존 데이터 물리 분리	라운지 결제 기록(12만 건) 논리적 테이블만 분리, 운영 DB와 동일 MySQL 인스턴스 내 물리 혼재, 운영 DB와 동일 계정으로 접근 가능, 침해 시 보존 데이터 12만 건 전체 노출 위험	전용 별도 MySQL 인스턴스 및 스토리지 구성(물리적 분리) 추진, 분리 DB 전용 접근 계정 별도 생성, 운영 DB 계정과 완전 분리 적용, 예산 미확보 시 이행 일정 위탁사와 사전 협의 후 서면 합의, 분리 완료 후 접근 권한 검증 테스트 및 위탁사 보고	IT운영팀장 박성민

3. 이행 점검 로드맵

개선방안 이행은 아래 3단계 로드맵에 따라 추진하며, 각 단계 완료 시 (주)하랑항공 개인정보보호팀에 이행 결과를 보고한다.

각 단계 완료 후 이행 결과보고서(증적자료 포함)를 (주)하랑항공 개인정보보호팀장에게 제출한다.

이행 중 기술적 제약, 예산 문제 등으로 일정 변경이 필요한 경우 사전 협의 후 서면 승인을 득하여야 한다.

단계	기간	주요 이행 항목	이행 결과 보고 기한
긴급 조치	~2026.04.30	공용계정 전환 착수 / 비인가 원격제어 프로그램 전량 삭제 / DLP USB 차단 정책 적용 / 공유폴더 개인정보 이관 / 여권 무단 촬영 직원 징계 / 카카오톡 공유 규정 위반 조치 / 포스트잇 비밀번호 제거 / 현장 서류 수거·파쇄 SOP 수립	2026년 05월 12일
단기 조치	~2026.07.12	침해사고 보고 절차 개정 / 비상연락망 갱신 / DR 훈련 실시 / 현장특화 교육 실시 / 방화벽 예외 홀 정비 / 재위탁 계약서 전면 개정 / 항공사 사전 승인 획득 / 마일리지 화면 여권번호 버그 수정	2026년 07월 12일
중기 조치	~2026.10.12	DB 논리 삭제 → 즉시 파기 프로세스 전환 / 물리적 DB 분리 서버 구축 / KMS 솔루션 도입 / 파기 결과 분기 보고 자동화 / 접속기록 해시값 검증 자동화	2026년 10월 12일
재점검	2026.11월 중	(주)하랑항공 현장 재점검 실시 — 전 항목 이행 완료 여부 및 잔존 취약점 재확인	2026년 11월 중

4. 결론 및 향후 조치 계획

(주)플라이메이트는 이번 점검에서 확인된 총 27건(취약 10건, 부분양호 17건)의 취약 사항에 대한 구체적인 개선방안을 수립하여 이행할 책임이 있다. 특히 무단 재위탁(항공사 사전 승인 없이 23명), 개인 스마트폰을 통한 여권 무단 촬영(45매), 카카오톡을 통한 개인정보 목적 외 공유(31건/월), 비인가 원격제어 프로그램 설치(14대), 교대조 공용 계정 운영(3개)은 현재 진행형 법적 위반 사항으로 즉각적인 시정이 요구된다.

위탁사인 (주)하랑항공은 수탁사의 이행 상황을 아래 일정에 따라 모니터링하고, 이행이 지연되거나 불충분한 경우 계약 조항에 따라 필요한 조치를 취할 수 있다.

4.1 향후 조치 일정

구분	일정	내용
조치계획서 제출	2026년 04월 29일까지	(주)플라이메이트 → (주)하랑항공 제출 (담당자 서명 필수)
긴급 항목 이행 보고	2026년 05월 12일까지	공용 계정·TeamViewer·포스트잇 PW·재위탁·여권 촬영·카카오톡 공유 이행 결과 보고
단기 항목 이행 보고	2026년 07월 12일까지	비상연락망·SHA-256·방화벽·DB 파기·관리대장·재수탁자 교육 이행 결과 보고
중기 항목 이행 보고	2026년 10월 12일까지	KMS·DB 물리적 분리·현장 특화 교육·취약점 조치 완료 이행 결과 보고
현장 재점검	2026년 11월 중	(주)하랑항공 주관 현장 재점검 실시 (전 항목 확인)